YAVUZLAR TASK 2

Feyzanur Yüksel

OWASP Juice Shop

Bu laboratuvarda OWASP 10 zafiyetleri şu şekilde listelenebilir:

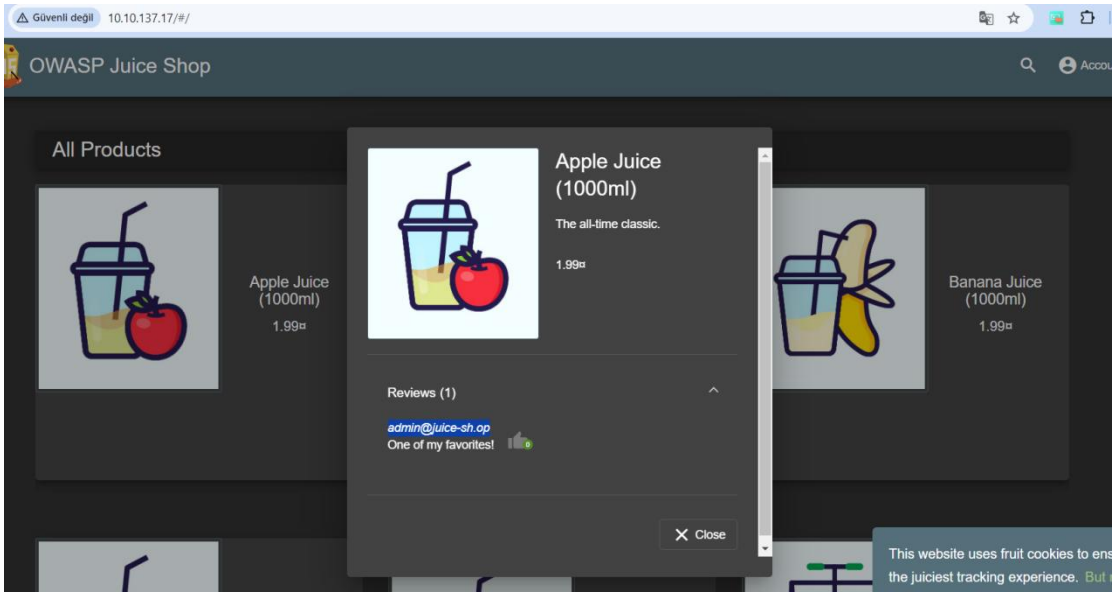
A03:2021-Injection
Question #4.SQL Injection,
Question #5.SQL Injection,
Question #11.XSS

A07:2021 – Identification and Authentication Failures
Question #6. Brute Force,
Question #7.Broken Authentication

A02:2021-Cryptographic Failures
Question #8.Sensitive Data Exposure
Question #9.Sensitive Data Exposure

A01:2021-Broken Access Control
Question #10

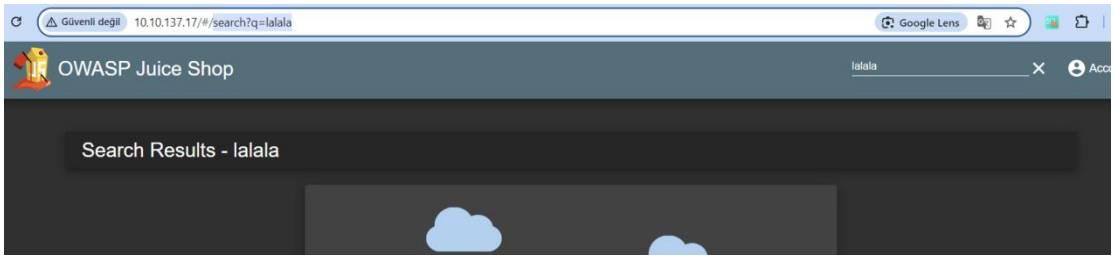
Question #1: What's the Administrator's email address?



Siteye girip ilk ürünün incelemelerine baktığımda adminin maili ile beraber yaptığı bir yorum karşıma çıkıyor.

Cevap: admin@juice-sh.op

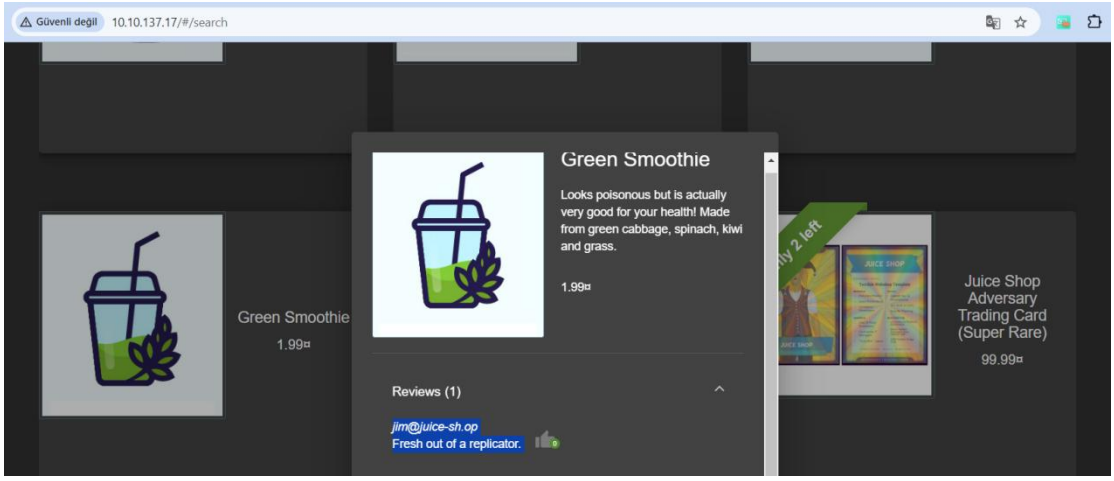
Question #2: What parameter is used for searching?



Arama barına rastgele bir kelime yazdığımda URL sonunda hangi arama parametresinin kullanıldığını görebiliyorum.

Cevap: q

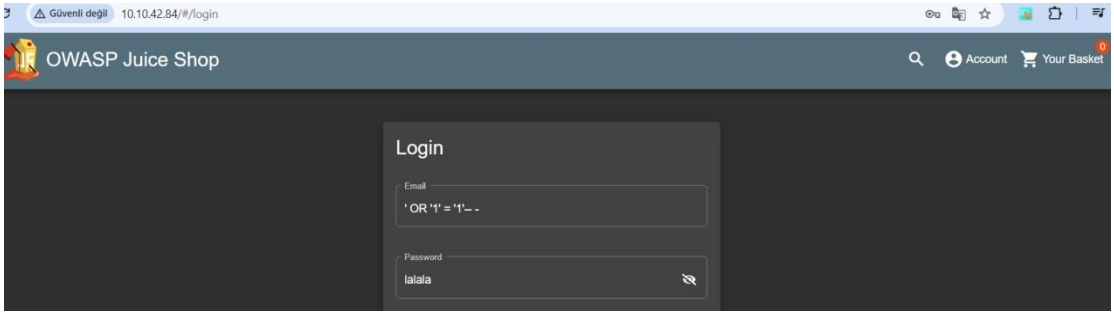
Question #3: What show does Jim reference in his review?



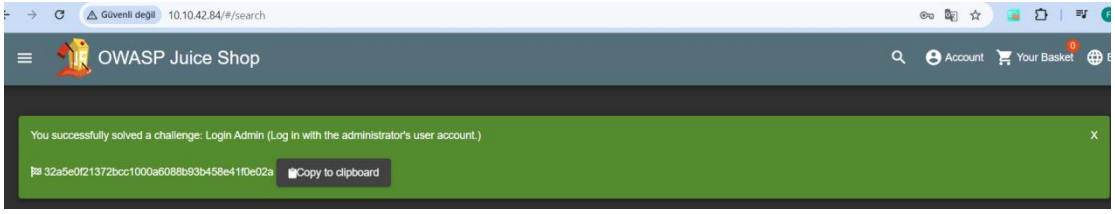
Ürün incelemelerine teker teker baktım ve Jim'in yorumuna ulaştım. Replicator kelimesini google üstünden arattığımda bunun Star Trek filmine ait bir gönderme olduğunu gördüm.

Cevap: Star Trek

Question #4: Log into the administrator account!

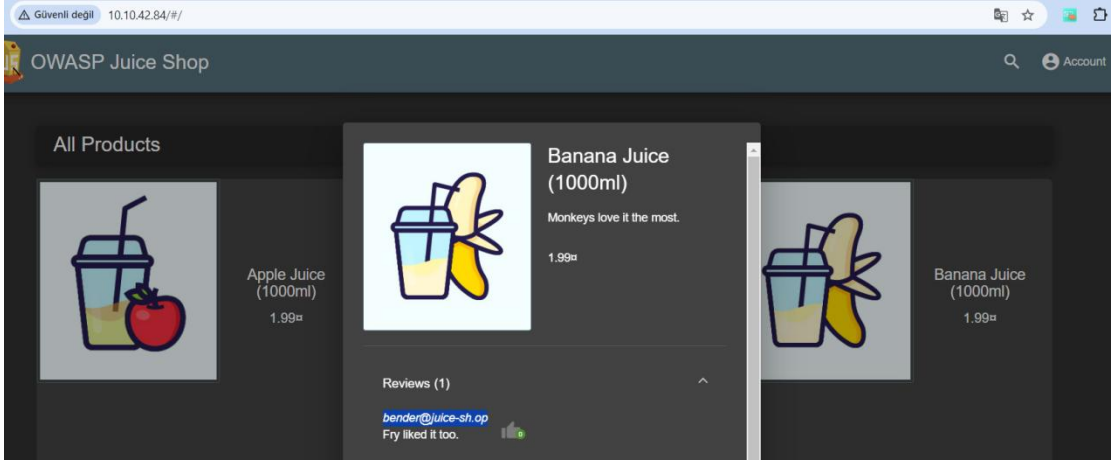


Admin hesabına girebilmek için bazı payloadlar denedim. ' OR '1' = '1'-- - payloadını kullandığımda admin hesabına başarıyla girdim ve flaga ulaştım.

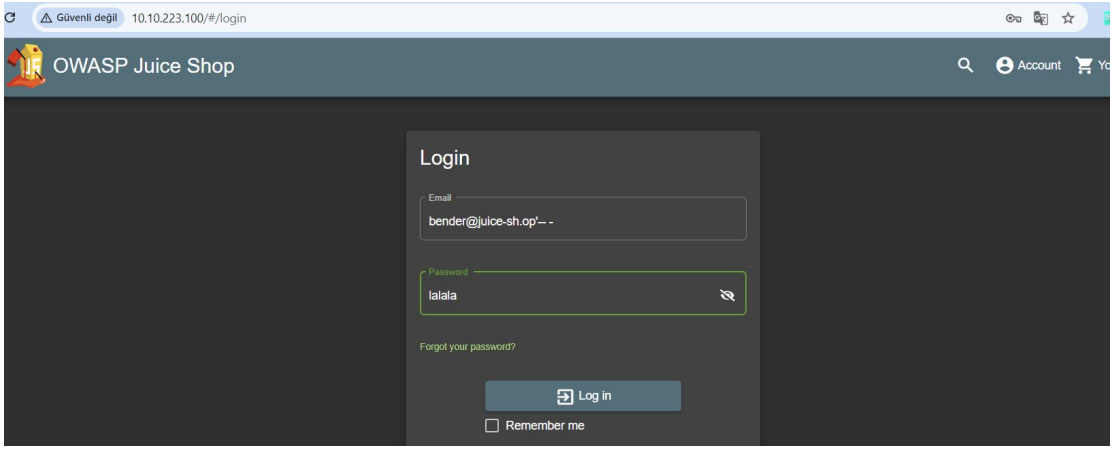


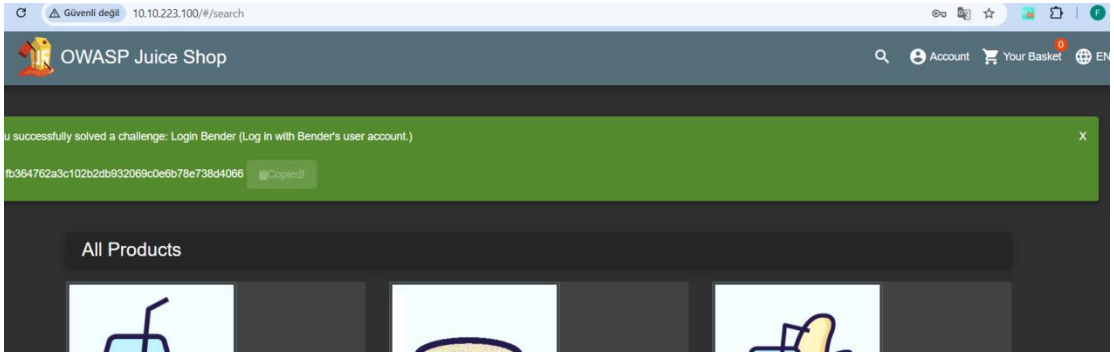
Cevap:32a5e0f21372bcc1000a6088b93b458e41f0e02a

Question #5: Log into the Bender account!



Öncelikle incelemelerden Bender'in mailine ulaştım. Bu soruda belirli bir mail gireceğim ve bu mail de doğru olacağından dolayı yalnızca ' -- payloadını girmem yeterli olacaktır.

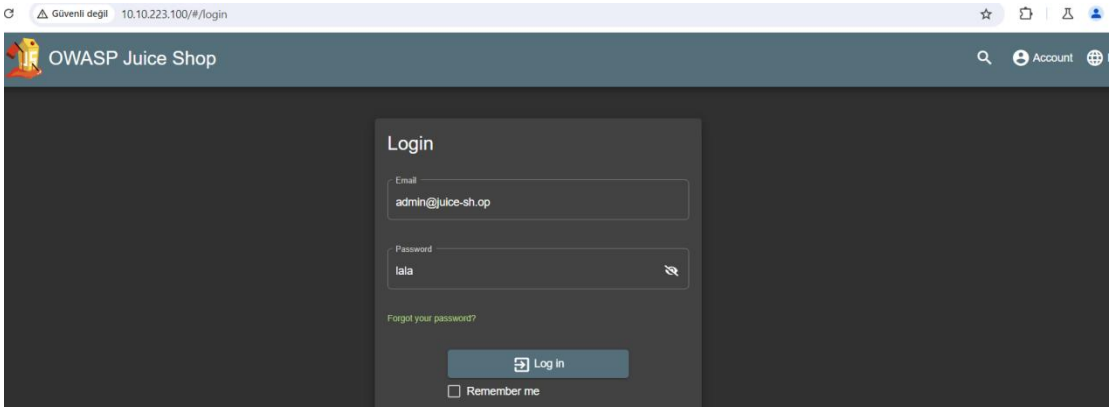




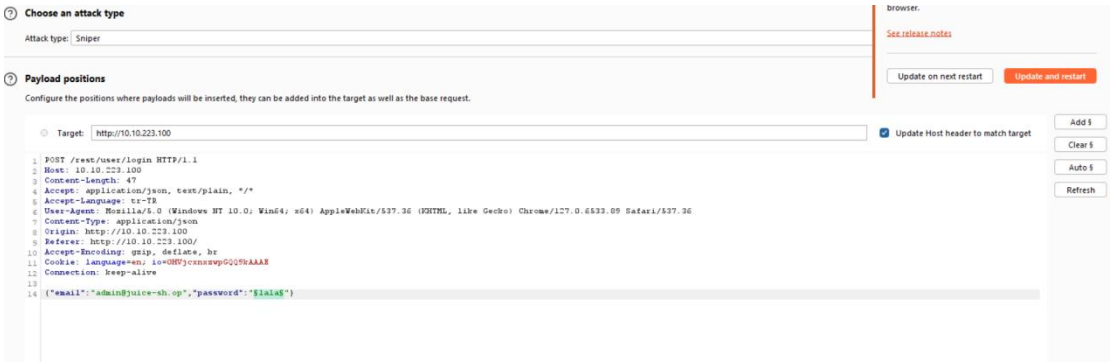
Cevap: fb364762a3c102b2db932069c0e6b78e738d4066

Question #6: Bruteforce the Administrator account's password!

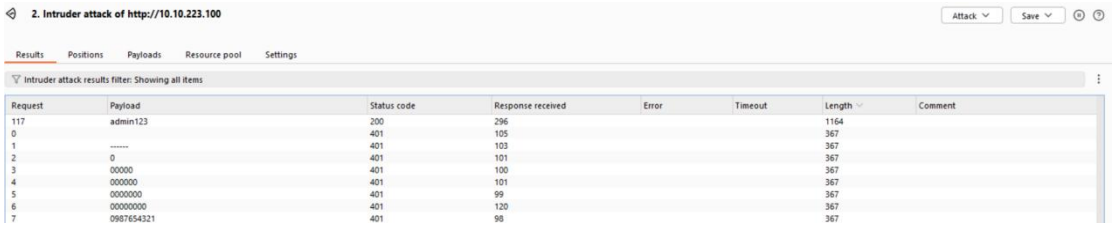
Bu soru için Burp Suite kullanmamız gerekiyor. Proxy açarak admin mailini ve rastgele bir şifreyi yazıp giriş yapıyorum.



Gelen isteği Burp Suite Proxy sekmesinden Intruder sekmesine gönderiyorum. Brute Force uygulamak istediğim password kısmı olduğu için bu kısmı seçip add butonuna tıklıyorum. Attack type olarak ise bilinmeyen ve şifreleri denemek istediğim bir yer olduğu için Sniper seçiyorum.



Sonrasında Payloads sekmesinden içinde denenecek şifrelerin olduğu txt dosyamı yüklüyorum. Start Attack butonuna basarak Brute Force saldırımı başlatıyorum. Her şifre denendiğinde çıkan sayfadaki karakterlerin uzunluğuna bakıyorum. Başarılı bir giriş olduğunda karakter sayısı gözle görülür şekilde farklı olacaktır.



2. Intruder attack of http://10.10.223.100

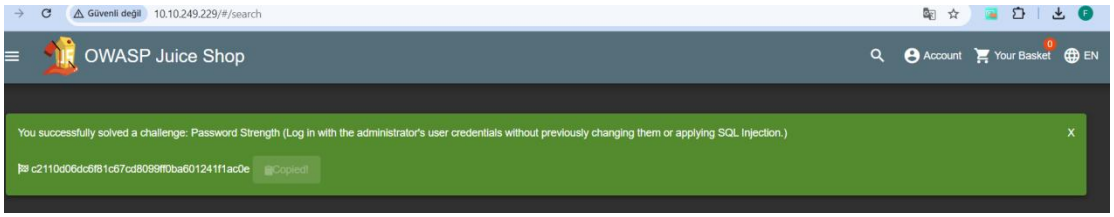
Attack | Save

Results | Positions | Payloads | Resource pool | Settings

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
117	admin123	200	296			1164	
0		401	105			367	
1	------	401	103			367	
2	0	401	101			367	
3	00000	401	100			367	
4	000000	401	101			367	
5	0000000	401	99			367	
6	00000000	401	120			367	
7	0987654321	401	98			367	

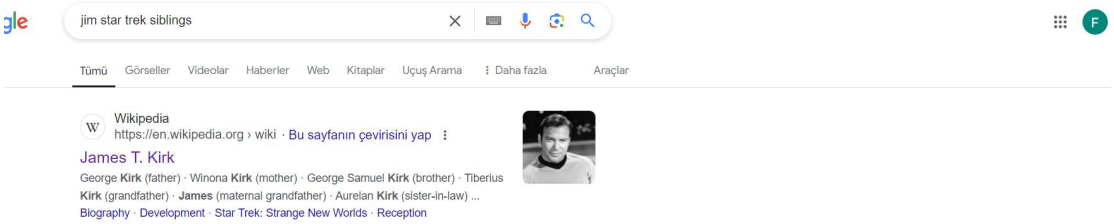
txt dosyasında 117 sırada olan admin123 payloadının admin hesabının şifresi olduğu açıkça görülüyor.



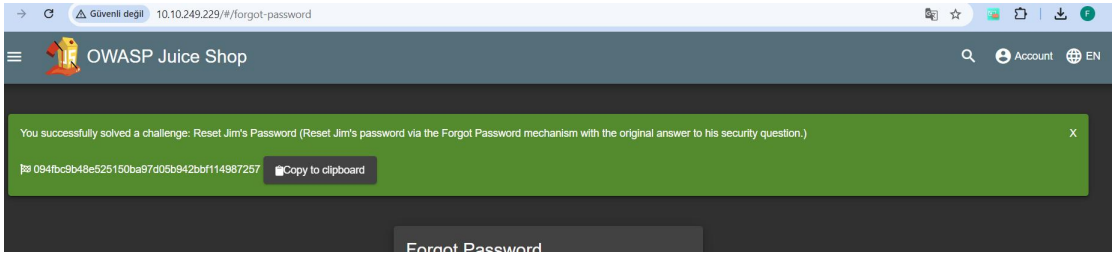
Cevap: c2110d06dc6f81c67cd8099ff0ba601241f1ac0e

Question #7: Reset Jim's password!

Jim'in mailine zaten ulaşmıştım. Jim'in maili ile şifremi unuttum butonuna tıkladığımda karşıma bir güvenlik sorusu çıkıyor. Jim ile ilgili tek bilgim Star Trek filmi olduğundan Google araması yapıyorum. Karşıma bir Star Trek karakteri ve aile bilgileri çıkıyor. Görüyorum ki bu karakterin bir erkek kardeşi var ve adı Goerge Samuel Kirk.



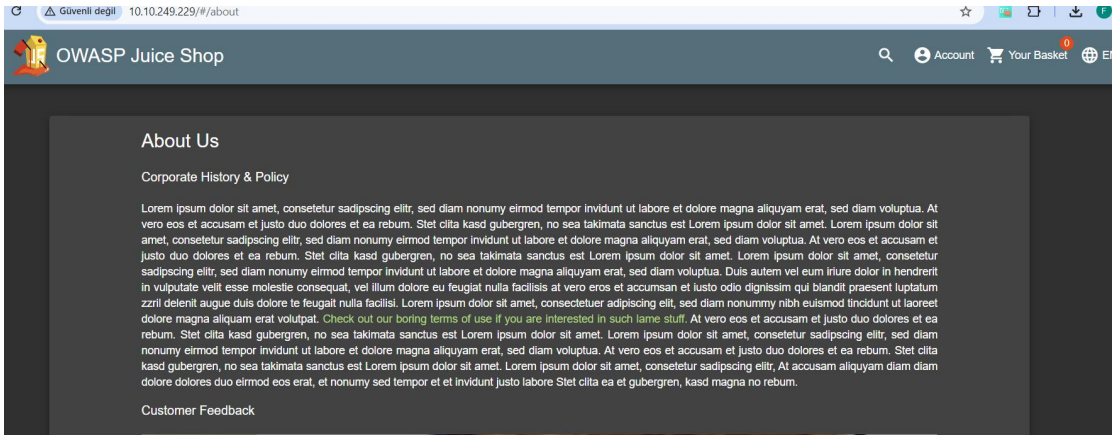
Güvenlik sorusunun cevabı olan Samuel anahtar kelimesini girdiğimde şifreyi istediğim gibi değiştirebiliyorum ve flag karşıma çıkıyor.



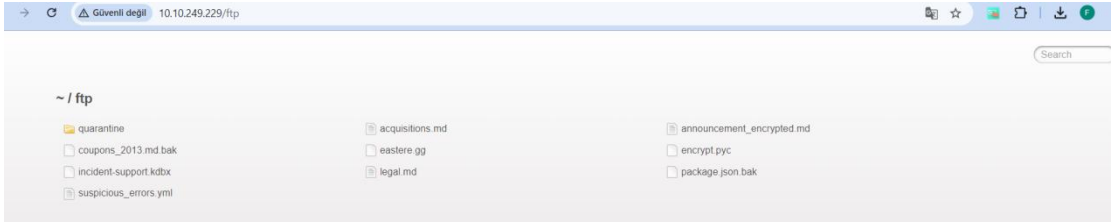
Cevap: 094fbc9b48e525150ba97d05b942bbf114987257

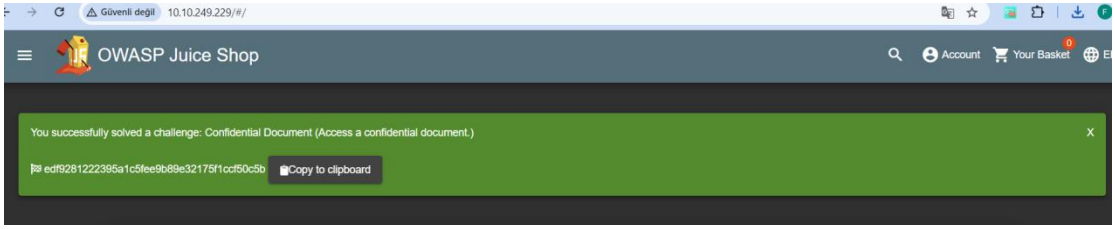
Question #8: Access the Confidential Document!

Site içinde biraz gezinip tıklanabilecek her yere tıkladığımda karşıma işe yaramayacak bazı şeyler, Sesame Street: Me Want It (Cookies) şarkısı gibi, ayrıca işe yarayacak bazı şeyler çıktı. About Us bölümünde ‘boring terms’ linkine tıkladığımda çıkan sayfanın URL sonunda bir dosya yolu gördüm ve geriye gitmeyi denedim.



Görüldüğü üzere özel dosyalara yetkisiz bir şekilde erişmiş oldum. Flag için tüm dosyaları indirdim ve göz attım. Sitenin ana sayfasına döndüğümde flag karşıma çıktı.

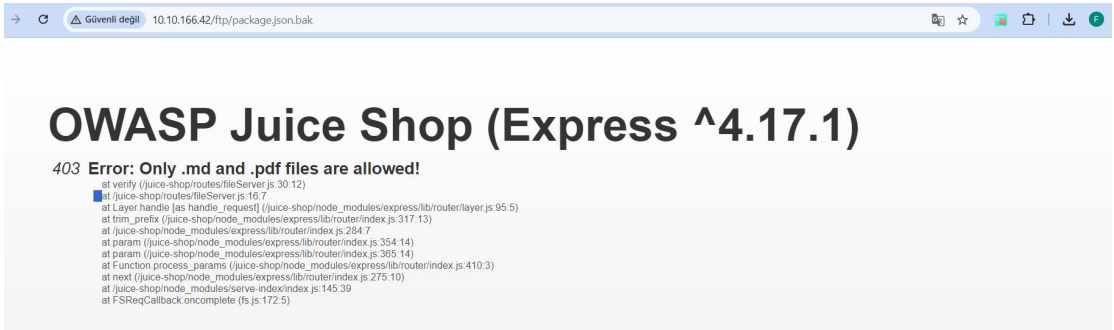




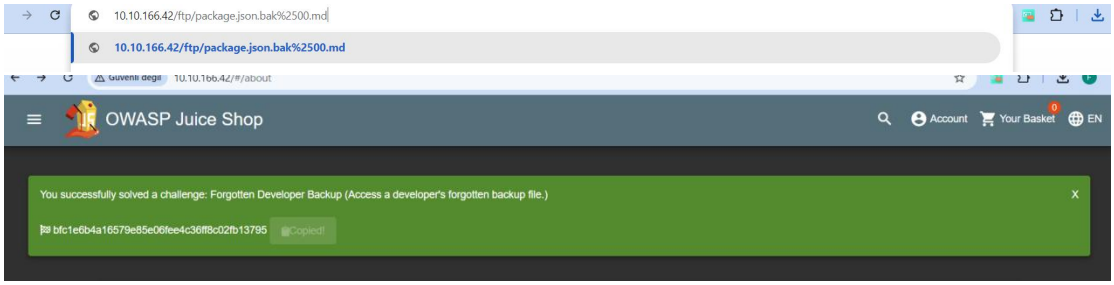
Cevap: edf9281222395a1c5fee9b89e32175f1ccf50c5b

Question #9: Download the Backup file!

Benden package.json.bak dosyasını indirmem isteniyor ancak indirmeye çalıştığımda sadece .md ya da .pdf uzantılarını indirmeye izin verildiği görülüyor.



Bu kısıtlamayı bypass etmek için URL kısmında düzenleme yapmak gerekiyor. İstediğim dosyanın sonuna null ekleyip izin verilen bir uzantı eklersem sunucu bu dosyanın gerçek uzantısını yok sayacaktır. URL encoder kullanarak %00 karşılığının %2500 olduğuna ulaşıyorum. Sonuna .md ekleyerek URL kısmını yazıyorum.



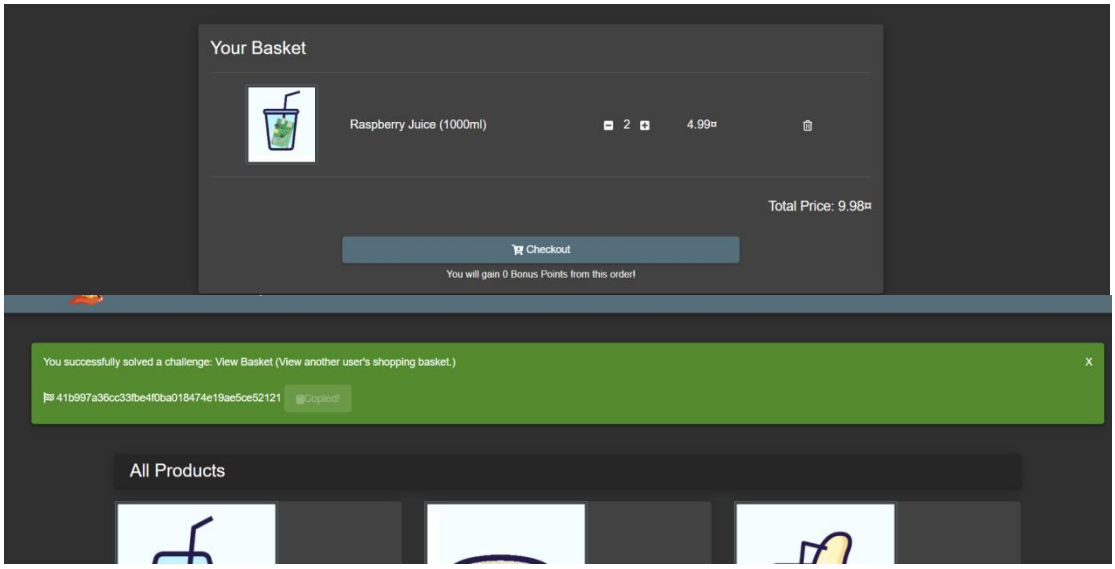
Cevap:bfc1e6b4a16579e85e06fee4c36ff8c02fb13795

Question #10: View another user's shopping basket!

Herhangi bir kullanıcı olarak giriş yapıp alışveriş sepetime tıklıyorum. Bu sırada Burp Suite intercept açık olduğundan isteği yakalıyorum.

Görüldüğü gibi GET isteği ile id 1 olan (admin hesabından girmiştim) sepet karşıma çıkıyor.

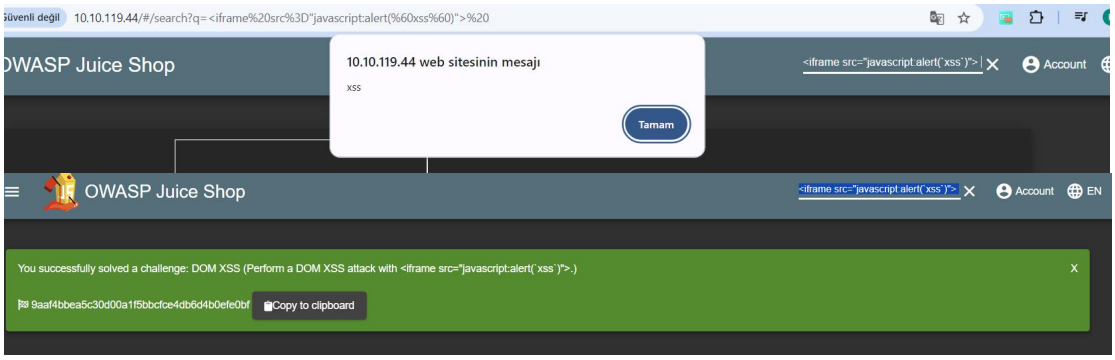
Bu istekteki id değiştirildiğinde ise farklı kullanıcıların sepetini görebiliyorum.



Cevap: 41b997a36cc33fbe4f0ba018474e19ae5ce52121

Question #11: Perform a DOM XSS!

Arama çubuğuna <iframe src="javascript:alert(`xss`)"> payloadını yazdığımda xss açığına ulaşıyorum.



Cevap: 9aaf4bbea5c30d00a1f5bbcfce4db6d4b0efe0bf